PHP : La classe 'Input' et ses classes dérivées

1. Présentation

Toutes les données provenant de l'utilisateur, doivent être contrôlées.
C'est un règle fondamentale en sécurité connue sous le sigle "never trust data client"
Les contrôles vont correspondre à ceux réalisés côté client à l'aide des propriétés suivante des objets input JavaScript :

- pattern, min, max maxLength, minLength, required

L'avantage du JavaScript est d'avoir intégré le contrôle à l'aide de la méthode checkValidity et la propriété validationMessage

Les classes 'Input' permettent la mise en œuvre de ces contrôles de conformité côté serveur.
Les contrôles n'étant pas les mêmes en fonction du type de la données (texte, date, url, mail, entier, liste de valeur, textarea), chaque type de données est associé à une classe dérivant de la classe Input

2. La classe Input

La classe Input est une classe **abstraite** donc non instanciable qui définit les attributs communs à tous les contrôles :

$Value	Valeur qui sera vérifiée. Cette propriété n'est pas typée puisqu'elle pourrait contenir différente valeur. Important : elle est initialisée à 'null' lors de l'instanciation
$Require	Booléen indiquant si la valeur est obligatoire.
$Unique	Booléen indiquant si la valeur doit être unique. Cette propriété n'est utile que si l'on doit vérifier que la valeur n'existe pas déjà dans une table par exemple.
$validationMessage	Chaîne de caractères stockant le message d'erreur éventuel après l'appel de la méthode checkValidity

Elle contient une seule méthode permettant de lancer la vérification :

- checkValidity()

La méthode contrôle simplement que la propriété Value est bien renseignée lorsque la propriété Require est vraie.

Chaque classe dérivée va redéfinir la méthode checkValidity pour la compléter avec ses règles spécifiques.

Il existe autant de classes dérivées que de types d'information à contrôler :
InputTexte, InputDate, IntputListe, InputUrl, InputEmail, InputInt, InputTextarea et InputFile

La notion de propriété n'existe pas en PHP, pour éviter d'écrire des accesseurs pour chaque attribut qui pourrait correspondre à une propriété, nous définissons l'attribut avec une visibilité 'public' et nous commençons son nom par une majuscule pour le différencier des attributs privés.

Dans une classe abstraite on doit normalement trouver au moins une méthode abstraite que les classes dérivées auront l'obligation de définir. Ce n'est pas le cas ici. Les classes dérivées vont simplement redéfinir la méthode checkValidity.
La classe Input est une classe abstraite de manière à interdire toute instanciation.

3. La classe InputText

Cette classe s'utilise pour tester la valeur de type chaîne de caractères.
Elle comporte de nombreuses propriétés supplémentaires :

Propriété	Rôle
$Pattern	Contient l'expression régulière que la valeur doit vérifier
$MinLength	Indique le nombre minimum de caractères devant composer la valeur
$MaxLength	Indique le nombre maximum de caractères devant composer la valeur
$EnMajuscule	Indique si la valeur sera automatiquement mise en majuscule
$EnMinuscule	Indique si la valeur sera automatiquement mise en minuscule
$SupprimerAccent	Indique si les accents seront automatiquement enlevés
$SupprimerEspaceSuperflu	Indique si les espaces superflus seront supprimés

Ces propriétés sont toutes facultatives.

La méthode checkValidity est redéfinie pour prendre en compte ses trois contrôles supplémentaires.

Exemple d'utilisation

```
$input = new InputText();
$input->Require = true;
$input->Unique = true;
$input->Pattern = "^[0-9A-Za-zÀÇÈÉÊàâçèéêëî](.*[A-Za-zÀÇÈÉÊàâçèéêëî!])*$";
$input->MinLength = 10;
$input->MaxLength = 70;
$input->Value = " Programmation Objet en PHP : Les classes Input";
if (!$input->checkValidity()) {
   $erreur = new Erreur('titre', $input->getValidationMessage());
}
```

4. La classe InputDate

Cette classe s'utilise pour tester la valeur d'une date au format MySQL aaaa-mm-jj.
Elle comporte deux propriétés supplémentaires :

- $Min indiquant la date la plus petite acceptée
- $Max indiquant la date la plus grande acceptée

La méthode checkValidity est redéfinie pour prendre en compte ses trois contrôles supplémentaires.

Une méthode statique decoderDate() est ajoutée afin de pouvoir retourner la date dans son format français : jj/mm/aaaa

Exemple d'utilisation

```
// la date de l'épreuve doit être renseignée et se situé dans l'année à venir
$input = new InputDate();
$input->Min = date("Y-m-d");
$input->Max = date('Y-m-d', strtotime('+ 1 year'));
$input->Value = "…";
if (!$input->checkValidity()) {
   $erreur = new Erreur('titre', $input->getValidationMessage());
}
```

5. La classe InputInt

Cette classe s'utilise pour tester la valeur d'une variable numérique de type entier
Elle comporte deux propriétés supplémentaires :

- $Min indiquant la valeur la plus petite acceptée
- $Max indiquant la valeur la plus grande acceptée

La méthode checkValidity est redéfinie pour prendre en compte ces deux contrôles supplémentaires.

6. La classe InputList

Cette classe s'utilise pour tester la valeur d'une variable qui doit appartenir à un ensemble de valeur
Elle comporte une propriété supplémentaire :

- $Values, un tableau contenant les valeurs acceptées

Cette propriété peut être alimentée par les données d'un table afin d'assurer un contrôle d'intégrité.

Exemple

```
$input = new InputList();
$input->Values = ['HIVER', 'PRINTEMPS', 'ETE', 'AUTOMNE'];
$input->Require = true;
```

```
$input = new InputList();
$input->Values = Coureur::getLesIdClubs();
```

7. La classe InputUrl

Cette classe s'utilise pour tester la valeur d'une url

Elle comporte une propriété supplémentaire :

- $VerifierExistence, un booléen initialement à false

La méthode checkValidity est redéfinie afin de vérifier par une expression régulière l'url
Si la propriété VerifierExistence est vraie la méthode vérifiera que l'url existe vraiment.

8. La classe InputEmail

Cette classe s'utilise pour tester la valeur d'une adresse électronique

Elle comporte une propriété supplémentaire : $MaxLength

L'adresse est vérifiée à l'aide de la fonction **filter_var** qui permet d'appliquer des filtres de validation sur une valeur. Le domaine de l'adresse mail est vérifié à l'aide de la fonction PHP checkdnsrr

9. La classe InputTextarea

Cette classe s'utilise pour tester la valeur saisie à partir d'un champ textarea.
La particularité est que l'on doit la plupart du temps accepter toutes les valeurs saisies. Cependant ce type de champ offre la possibilité de mettre en œuvre une faille XSS (injection de code Javascript par exemple)
Il faut donc personnaliser la méthode checkValidity afin de :

- supprimer toute valeur qui contiendrait une balise <script …>
- encoder les caractères spéciaux HTML (fonction htmlspecialchars) ou supprimer les balises HTML sauf exception (fonction strip_tags)

Pour supprimer les balises <script>, l'expression régulière suivante (insensible à la casse) est utilisée :

```
<script[^>]*>.*?</script>
```

**? va limiter la correspondance en cherchant le sous ensemble de caractères le plus petit qui satisfait la condition. Cela revient à isoler les caractères entre une balise <script> et sa balise </script>. Sans ? tous les caractères entre la première balise <script> et la dernière balise </script> seraient concernés.*

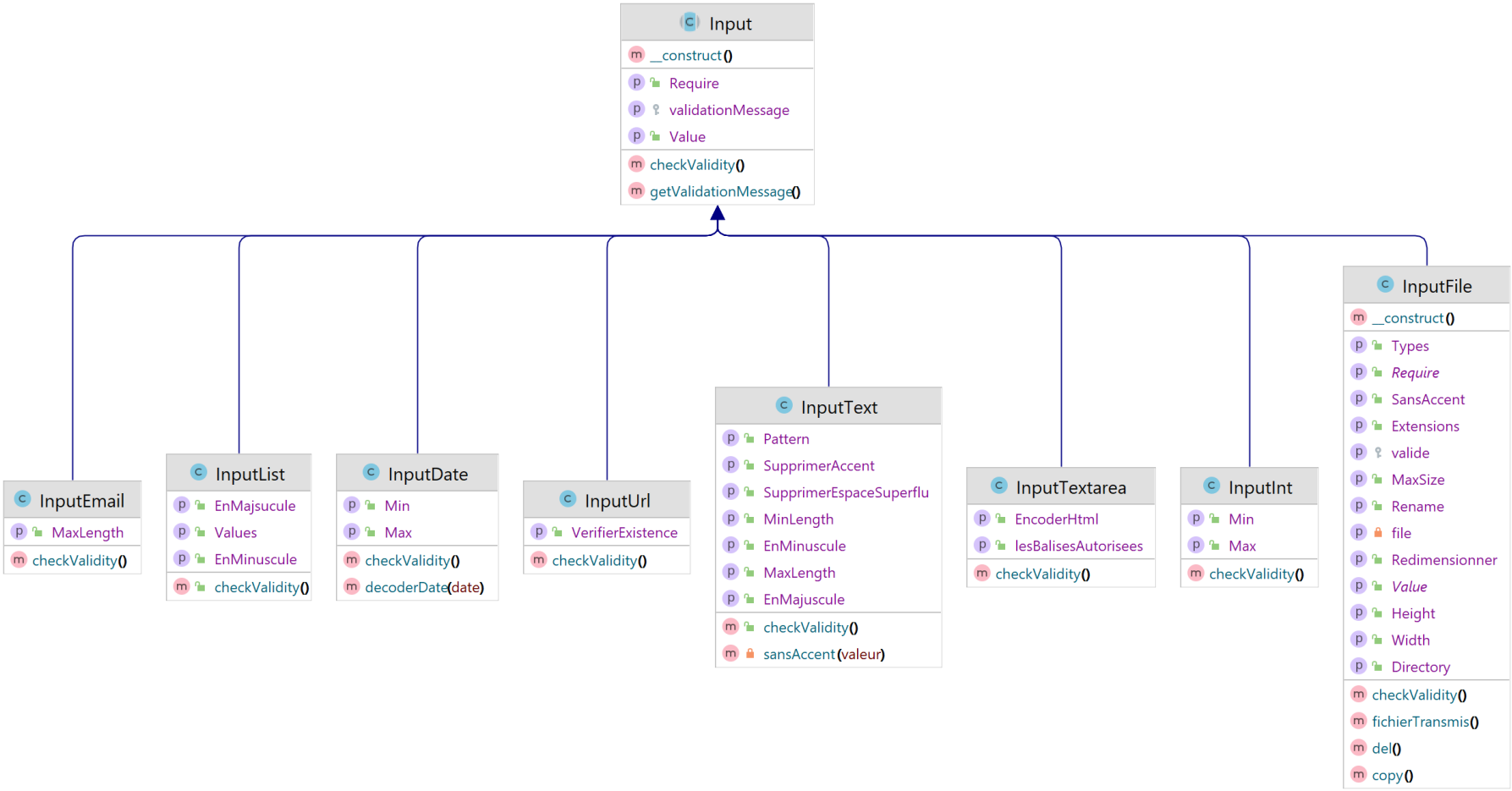
Il faut noter que si l'on utilise un composant de type Rich Text Editor comme CkEditor ou Tiny MCE la valeur retournée est automatiquement convertie en HTML et les caractères sont aussi automatiquement échappés ce qui rend impossible l'injection de code.

Cette classe comporte deux propriétés supplémentaires :

- $EncoderHtml, un booléen initialement à false qui pour la valeur 'true' déclenchera l'encodage les caractères spéciaux HTML.
- $lesBalisesAutorisees, un tableau qui contient les balises HTML qui ne seront pas supprimées si l'encodage n'est pas demandé

Remarque : l'encodage avec la fonction htmlspecialchar() nécessite de réaliser l'opération inverse pour afficher la valeur (fonction htmlspecialchars_decode). Cela oblige de parcourir les données retournées par une requête select pour appliquer cette fonction sur les colonnes concernés. Il me parait suffisant de supprimer les balises HTML et ainsi de conserver dans la table une données non encodée tout en garantissant un haut niveau de sécurité.

10. La classe InputFile

Cf document 'La classe InputFile.pdf'

11. Diagramme de classe correspondant